

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Asset Management	The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to business objectives and the organization's risk strategy.	Physical devices and systems within the organization are inventoried.	1. Do you an up to date CMDB or asset inventory of all physical (hardware) device? 2. How you perform periodic review on the CMDB to ensure that it's accurate and up to date?	Pass	CMDB Needs periodic reviews.
		Software platforms and applications within the organization are inventoried.	1. Do you an up to date CMDB or asset inventory of all software assets such as critical applications? 2. How you perform periodic review on the CMDB to ensure that it's accurate and up to date?	Fail	SaaS applications should be added to CMDB, they should be classified as per sensitivity and criticality.
		Organizational communication and data flows are mapped.	1. Do you have clear, up to date, network diagrams - including the cloud environment?	Pass	
		External information systems are catalogued.	1. Does your CMDB include Software-as-a-Service (SaaS) instance catalogued and classified as per sensitivity and criticality? 2. Do you have an up to date inventory of all third party suppliers?	Fail	SaaS applications are used but not catalogued in the CMDB or classified by sensitivity or criticality. No third-party risk management or supplier inventory process is in place; vendors are not centrally tracked by IT or security.
		Resources (e.g., hardware, devices, data and software) are prioritized based on their classification, criticality and business value.	1. Are assets in the CMDB classified based on sensitivity and criticality?	Fail	No CMDB or asset classification in place.
		Cybersecurity roles and responsibilities for the entire workforce and third-party stakeholders (e.g., suppliers, customers, partners) are established.	1. Are cyber security roles and responsibilities defined? 2. Is there a clear information security policy outlining roles and responsibilities for cyber security (including third part suppliers) ?	Fail	Roles and responsibilities are not defined; cyber security tasks are assigned to IT staff. No formal information security policy exists.
Business Environment	The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform cybersecurity roles, responsibilities, and risk management decisions.	The organization's role in the supply chain is identified and communicated.	1. Does the organisation have clear documentation outlining their role within their own supply chain when it comes to cyber security? This is accomplished by having a clear mapping of third party suppliers, classifying suppliers based on criticality and sensitivity.	Fail	No supplier mapping or classification process exists; supply chain cyber roles are undocumented.
		The organization's place in critical infrastructure and its industry sector is identified and communicated.	1. Is this organisation considered 'critical infrastructure' ? Examples of this will include intelligence agencies, national communication organisations, transportation, etc. These are organisations that are part of 'national security'. If the answer is YES, then this needs to be documented in the information security policy and communicated clearly to senior stakeholders.	N/A	Oscorp is not a critical infrastructure organisation
		Priorities for organizational mission, objectives and activities are established and communicated.	The organisation has a clear business strategy and mission statement.	Pass	
		Dependencies and critical functions for delivery of critical services are established.	1. Does the organisation have key critical services and applications inventories and classified? 2. Does the organisation have business continuity plans and disaster recovery plans for key critical services?	Fail	No inventory or classification (critical and sensitivity) of critical services and applications exists. The organisation should have a clear list of their key critical assets at minimum.
		Resilience requirements to support delivery of critical services are established.	1. Determine if the organization's business continuity and disaster recovery plans (including business impact analysis) support resilience of critical services. 2. Determine if appropriate due diligence (e.g., business continuity plans (BCP), service level agreements (SLA), Service Organization Control (SOC) reports) information is in place and reviewed to ensure resilience requirements of the organization can be met by critical third-party services.	Fail	No third-party risk management or due diligence process exists; supplier resilience is not assessed.
Policies and Procedures	The policies, procedures, and processes to manage and monitor the organization's regulatory requirements are established.	Organizational information security policy is established.	1. Does the organisation have an information security policy?	Fail	They have no formal information security policy
		Information security roles and responsibilities are coordinated and aligned with internal roles and external partners.	1. Have information security roles and responsibility been documented and communicated with internal and external stakeholders (i.e. third party suppliers) ?	Fail	No information security roles are documented or communicated internally or to third parties.

Sub-Category	Control Objective	Control description	Questions to ask	Pass/ Fail	Comments
Governance	The organization's legal, risk, environmental, and operational requirements are understood and inform the management of cybersecurity risk.	Legal and regulatory requirements regarding cybersecurity, including privacy and civil liberties obligations, are understood and managed.	1. The organisation's legal and regulatory responsibilities from an information security point of view is well documented. This includes complying with privacy laws and other cyber security regulations.	Fail	Legal and regulatory obligations for cybersecurity and privacy are not documented or managed.
		Governance and risk management processes address cybersecurity risk.	1. The organisation has a mature and established processes and procedures to manage cyber security risks. 2. The board of directors have oversight of information security issues (governance)	Fail	No formal cyber risk management processes exist. Cybersecurity oversight is not assigned to the board; responsibility is defaulted to IT.
Risk Assessment	The organization understands the cybersecurity risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals.	Asset vulnerabilities are identified and documented.	1. Vulnerability scans are conducted and vulnerabilities are analysed and documented.	Fail	Vulnerability scans are performed ad-hoc with no formal analysis or documentation process.
		Threat and vulnerability information is received from information sharing forums and sources.	1. vulnerability management program includes subscriptions to various threat intelligence sources to get information about the latest threats and vulnerabilities.	Fail	There is no cyber security team or a cyber security function to do this activity.
		Threats, both internal and external, are identified and documented.	1. Cyber security threats assessments have been conducted 2. threat actors have been identified, assessed, and documented	Fail	No formal threat assessments have been performed. Threat actors are not identified or documented.
		Potential business impacts and likelihoods are identified.	1. Cyber security risk assessments include business impact and likelihood as a critical step to determine the level of risk	Fail	No cyber risk assessments are conducted, so impacts and likelihoods are not evaluated.
		Threats, vulnerabilities, likelihoods and impacts are used to determine risk.	1. Determine if the risk assessment process identifies reasonably foreseeable internal and external threats and vulnerabilities, the likelihood and potential damage of those threats, and the sufficiency of controls to mitigate the risk associated with those threats.	Fail	No formal risk assessment process exists; threats, vulnerabilities, and impacts are not evaluated.
		Risk responses are identified and prioritized.	1. Are recommendations/outcomes of the risk assessment process prioritised based on criticality and impact to the business?	Fail	No risk assessment process exists, so risk responses are not identified or prioritized
Risk Management Strategy	The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.	Risk management processes are established, managed and agreed to by organizational stakeholders.	1. Has the risk management process been endorsed by senior management?	Fail	No cyber risk management process exists, so there is nothing for senior management to endorse
		Organizational risk tolerance is determined and clearly expressed.	1. Determine if the organization has defined and approved a cyber risk appetite statement. This will be derived from the risk tolerance of the organisation.	Fail	No cyber risk appetite or tolerance statement exists.
		The organization's determination of risk tolerance is informed by its role in critical infrastructure and sector-specific risk analysis.	1. If the organisation is considered a critical infrastructure, then the cyber risk and overall risk tolerance should take this into consideration.	N/A	Oscorp is not a critical infrastructure organisation